

במפגש החמישי (שהועבר כהקלטה במקום שיעור פרונטלי), המרצה מיכאל סיים את הנושאים של המפגש הקודם (Zero Day ופתרונות הגנה) ועבר לנושא המרכזי של השיעור: **ניהול סיכונים בסייבר 1**.
להלן סיכום הנושאים העיקריים:

1. השלמות ממפגש 4: פתרונות הגנה ומדידה

- **סנדבוקס (Sandbox) וציידים:** שימוש בסביבה מבודדת המאפשרת ללמוד את דפוסי ההתנהגות של התוקף ("Hunters") מבלי לסכן את המערכת האמיתית 2, 3.
- **מטריית הפתרונות המודרנית:**
- **Zero Trust:** מתודולוגיה של "אל תסמוך על אף אחד", הכוללת אימותים מרובים ומיקרו-סגמנטציה לבידוד פורצים 4.
- **EDR/XDR:** שימוש ב-AI לניטור אנומליות וסטיות תקן בזמן אמת בנקודות הקצה ובתוך הרשת 5, 6.
- **WAF (Web Application Firewall):** הגנה אפליקטיבית לחסימת תכני HTTP (נחשב לפתרון וותיק שחלק מהלקוחות מחליפים בפתרונות 7, 8 EDR/Zero Trust).
- **מדדי ביצוע (Metrics):** השאיפה היא ל-MTTR (זמן תגובה ממוצע) של **פחות מ-60 דקות**, וביצוע פאצ'ים לבעיות קריטיות תוך 24 שעות (אם כי זה לא תמיד פרקטי) 9.

2. ניהול סיכונים (Risk Management)

- ניהול סיכונים הוא תהליך מובנה לזיהוי, הערכה והפחתה של סיכונים, הכולל תוכנית מגירה למקרה שהסיכון יתממש 10. המטרה אינה לפתור את כל הסיכונים, אלא למפותם ולהבין את הנזק הפוטנציאלי 11, 12.
- **הגבול הדינמי:** המרצה השתמש במטאפורה של "ג'רי והכלב" כדי להמחיש שגבולות ההגנה משתנים כל הזמן עם הופעת שיטות תקיפה חדשות 13, 14.
 - **גורמי סיכון בראיית CISO:** ממשקי צד שלישי (חולשה משמעותית כי אין שליטה על הגנת הספק), עבודה בענן, גיבויים, תמיכה מרחוק (Remote Connection), תוכניות BCP/DRP ומיקום פיזי של שרתים (למשל, קרבה פיזית למשרדים של חברות אחרות) 15-19.
 - **מודל SWOT:** שימוש במודל למיפוי **חוזקות, חולשות, הזדמנויות ואיומים** של המוצר או הארגון 10, 20. חולשה (כמו ממשק UI גרוע) יכולה להפוך להזדמנות לשיפור 21.

3. תהליך ניהול הסיכונים בפועל

התהליך מורכב מחמישה שלבים 22-24:

1. **זיהוי סיכונים:** סיכוני שוק ורגולציה (כמו GDPR או FDA), סיכונים פיננסיים (אינפלציה, שער חליפין), סיכונים תפעוליים (אנשי מפתח) ומשפטיים 24-26.
2. **הערכת סיכונים:** ניתוח הסיכון לפי שני פרמטרים: **הסבירות** שיקרה ו**ההשפעה** (אימפקט) שלו 27, 28.
3. **התמודדות:** קביעת אסטרטגיה להפחתת הסיכון 23.
4. **ניטור ובקרה:** מעקב לאורך זמן לוודא שהסיכון לא חוזר 24.
5. **דיווח:** כתיבת מסקנות להנהלה הבכירה 24, 29.

4. רמות חומרה (Severity Levels)

בניתוח הסיכונים והבאגים, נהוג לחלק את הממצאים לדרגות 30, 31:

- **דרגה 4 (קטסטרופלי):** באגים שחייבים לתקן מיידית ("אתמול").
- **דרגה 3 (קריטי):** משפיע על המערכת אך לא מפיל אותה לחלוטין.
- **דרגה 2:** סביר שיקרה, אך ללא נזק משמעותי.
- **דרגה 1:** באגים קוסמטיים או קטנים (כמו פסיק חסר ב-UI).

המרצה סיכם כי בניהול סיכונים לא מחפשים פתרון לכל בעיה, אלא הבנה של המערכת ויצירת תוכניות מגירה
12.